

Università Ca' Foscari Venezia

Dipartimento di Economia

LAUREA MAGISTRALE IN
ECONOMIA E FINANZA

Vigilanza regolamentare: governo societario, controlli interni e remunerazioni

Punto 8 del programma — la vigilanza regolamentare sull'organizzazione

Appunti di:

Silvio Angelo Baratto Roldan

Codice insegnamento:

EM2101

Contenuto:

9 domande d'esame

Anno Accademico:

2026/2027

Preparazione personale alla prova orale di Legislazione Bancaria (EM2101, mod. 2, prof. Alberto Urbani), costruita sul materiale del corso e sulle fonti normative. Non è materiale ufficiale del docente.

Indice

1	Vigilanza regolamentare: governo societario, controlli interni e remunerazioni	1
1.1	D1 — Il fondamento normativo della vigilanza regolamentare sull’organizzazione	1
1.2	D2 — Il principio di proporzionalità e la classificazione delle banche	2
1.3	D3 — Supervisione strategica, gestione e controllo: l’approccio funzionale . . .	4
1.4	D4 — Gli amministratori indipendenti e i componenti non esecutivi	5
1.5	D5 — Il Risk Appetite Framework: nozione e articolazione	6
1.6	D6 — Il sistema dei controlli interni: nozione, finalità e principi di organizzazione	7
1.7	D7 — I tre livelli di controllo e le «tre linee di difesa»	8
1.8	D8 — Compliance, risk management e internal audit: contenuti specifici	9
1.9	D9 — Le politiche di remunerazione e incentivazione: fondamento e principi generali	10

1 | Vigilanza regolamentare: governo societario, controlli interni e remunerazioni

Questo capitolo copre l'area nella quale la vigilanza regolamentare incide più profondamente sull'autonomia organizzativa della banca: il governo societario, il sistema dei controlli interni, il sistema informativo e la continuità operativa, le politiche di remunerazione e incentivazione. Il perno è l'art. 53, co. 1, lett. d), TUB — replicato per il consolidato dall'art. 67, co. 1, lett. d) — attuato dalla Circolare della Banca d'Italia n. 285 del 17 dicembre 2013, Parte Prima, Titolo IV, e in particolare dai suoi Capitoli da 1 a 5; il Capitolo 6, dedicato al governo e alla gestione del rischio di liquidità, appartiene allo stesso Titolo ma esula da questa unità. Il docente tende a entrare dall'alto: chiede la norma primaria, poi domanda «perché una banca non può organizzarsi come qualunque altra società per azioni?». Da lì scende per gradi — dalla scelta del modello al progetto di governo societario, dalla composizione degli organi ai comitati endoconsiliari, dal RAF alle funzioni aziendali di controllo, fino alle remunerazioni. Il filo logico da tenere è sempre lo stesso: l'organizzazione interna non è un affare privato dei soci, perché è essa stessa un presidio prudenziale; di qui il duplice registro della Circolare, che fissa principi generali vincolanti nell'obiettivo e lascia alla banca la scelta dei mezzi, secondo proporzionalità. Gli istituti del modulo 1 — autorizzazione, assetti proprietari, requisiti degli esponenti — si danno qui per acquisiti e si richiamano solo dove servono a chiudere il ragionamento.

1.1. D1 — Il fondamento normativo della vigilanza regolamentare sull'organizzazione

Domanda. Su quale base normativa la Banca d'Italia disciplina il governo societario e i controlli interni delle banche, e come si articola oggi quella disciplina?

Risposta da dare. Il fondamento è l'art. 53, co. 1, lett. d), TUB, che abilita la Banca d'Italia a emanare disposizioni di carattere generale aventi a oggetto «il governo societario, l'organizzazione amministrativa e contabile, nonché i controlli interni e i sistemi di remunerazione e di incentivazione». La norma gemella per la vigilanza su base consolidata è l'art. 67, co. 1, lett. d), TUB. L'attuazione sta nella Circolare della Banca d'Italia n. 285 del 2013, Parte Prima, Titolo IV.

Spiegazione. L'art. 53 elenca i quattro ambiti della vigilanza regolamentare: adeguatezza patrimoniale, contenimento del rischio, governo societario e organizzazione, informativa al pubblico. Va segnalato che la lettera c), relativa alle **partecipazioni detenibili**, è stata abrogata dal d.lgs. 31 dicembre 2025, n. 208, con effetto dal 9 gennaio 2026: la materia è oggi rimessa alla disciplina europea direttamente applicabile. È un'avvertenza pratica, perché quasi tutta la manualistica e gli appunti in circolazione presentano ancora l'art. 53 con quattro lettere piene.

La lettera d) ha avuto un'espansione significativa. Nella formulazione originaria si riferiva soltanto all'organizzazione amministrativa e contabile e ai controlli interni; il governo societario e i sistemi di remunerazione e incentivazione vi sono stati aggiunti dall'art. 22, co. 2, lett. a), n. 1), della legge 15 dicembre 2011, n. 217. Non è un dettaglio lessicale: è il momento in cui la vigilanza acquista un titolo espresso per entrare nella *governance* in senso proprio, cioè nel rapporto fra organi sociali, e non solo nelle procedure contabili. Va inoltre notato che l'alinea del comma 1 è stato modificato dal d.lgs. 12 maggio 2015, n. 72, che ha eliminato il riferimento alla conformità alle deliberazioni del CICR: la Banca d'Italia emana oggi quelle disposizioni in via autonoma.

La disciplina di secondo livello è contenuta nel Titolo IV della Parte Prima della Circolare 285, articolato in sei capitoli: governo societario (Cap. 1), politiche e prassi di remunerazione e incentivazione (Cap. 2), sistema dei controlli interni (Cap. 3), sistema informativo (Cap. 4), continuità operativa (Cap. 5), governo e gestione del rischio di liquidità (Cap. 6). A monte stanno la CRD — la direttiva 2013/36/UE, come modificata dalla direttiva (UE) 2019/878, c.d. CRD V — e, per i profili di *fit and proper*, il d.m. 23 novembre 2020, n. 169. Si è preferito lo strumento della direttiva perché la banca resta una società di diritto comune, e il diritto societario non è materia armonizzata: l'ordinamento europeo detta i risultati, il legislatore nazionale li innesta sul proprio diritto commerciale.

1.2. D2 — Il principio di proporzionalità e la classificazione delle banche

Domanda. Come opera il principio di proporzionalità nella disciplina del governo societario, e secondo quali criteri le banche sono classificate?

Risposta da dare. La proporzionalità è il criterio che consente di applicare la stessa disciplina a intermediari strutturalmente diversi senza snaturarla. La Circolare 285, Parte Prima, Titolo IV, Capitolo 1, Sezione I, par. 4.1, stabilisce che le banche applicano le disposizioni «con modalità appropriate alle loro caratteristiche, dimensioni e complessità operativa», e a questo fine distingue tre categorie: banche di maggiori dimensioni o complessità operativa, banche intermedie, banche di minori dimensioni o complessità operativa.

Spiegazione. Il criterio primario è presuntivo. Sono presunte **banche di maggiori dimensioni o complessità operativa** le banche considerate significative ai sensi dell'art. 6, par. 4, del Regolamento (UE) n. 1024/2013 — cioè quelle sottoposte alla vigilanza diretta della BCE —

e le banche quotate; sono **banche intermedie** quelle con un attivo compreso fra 5 e 30 miliardi di euro, calcolato come media dei quattro esercizi immediatamente precedenti; sono **banche di minori dimensioni o complessità operativa** quelle con attivo pari o inferiore a 5 miliardi, calcolato con lo stesso criterio.

Categoria	Criterio presuntivo
Maggiori dimensioni o complessità	significative ex art. 6(4) Reg. (UE) 1024/2013; banche quotate
Intermedie	attivo fra 5 e 30 miliardi di euro (media quadriennale)
Minori dimensioni o complessità	attivo pari o inferiore a 5 miliardi di euro (media quadriennale)

La presunzione non è rigida in un senso e lo è nell'altro. Se la banca ritiene che il criterio dimensionale non sia sufficientemente significativo, entrano in gioco criteri qualitativi: la tipologia di attività svolta — le strategie orientate al risparmio gestito o alla negoziazione configurano spesso complessità; la struttura proprietaria — il controllo totalitario da parte di un intermediario estero può ridurre la complessità, mentre rilevanti interessi di minoranza possono accrescerla; l'appartenenza a un gruppo bancario; l'appartenenza a un network operativo che offra servizi e infrastrutture di categoria. È in questo spazio che si colloca l'**autovalutazione**: la banca può collocarsi in una categoria diversa da quella suggerita dall'attivo, motivandolo. In senso opposto, però, la Circolare è categorica: le banche significative e le banche quotate sono **sempre** considerate di maggiori dimensioni o complessità operativa, e su questo non è ammessa autovalutazione in diminuzione.

Vi è poi una regola specifica per il credito cooperativo: non rientrano fra le banche di maggiori dimensioni o complessità operativa le banche di credito cooperativo appartenenti a un gruppo bancario cooperativo, salvo diversa determinazione in esito al processo di autovalutazione. La collocazione non resta interna: fra gli obblighi di informativa al pubblico previsti dalla Sezione VII vi è l'indicazione motivata della categoria in cui la banca si è collocata.

Le conseguenze pratiche sono rilevanti. Solo nelle banche di maggiori dimensioni o complessità operativa devono essere costituiti i tre comitati endoconsiliari e formalizzati i piani di successione per le posizioni di vertice; nelle banche intermedie è obbligatorio il solo comitato rischi; nelle banche di minori dimensioni l'istituzione di comitati risponde a concrete esigenze. Si gradua lungo la stessa scala anche il numero dei consiglieri, perché le banche diverse da quelle di maggiori dimensioni devono attestarsi su numeri inferiori. Altre discipline del Titolo IV adottano invece criteri propri, e confonderle è un errore: il Capitolo 2 gradua il differimento e il pagamento in strumenti finanziari sulla nozione di banca significativa ai sensi dell'art. 6, par. 4, del Regolamento (UE) n. 1024/2013 e su una definizione autonoma di banche di minori dimensioni; il Capitolo 5 individua nominativamente, con apposita comunicazione, i destinatari dei requisiti particolari di continuità operativa, sulla base della quota di mercato detenuta.

1.3. D3 — Supervisione strategica, gestione e controllo: l'approccio funzionale

Domanda. La Circolare 285 non detta una disciplina distinta per il modello tradizionale, dualistico e monistico. Come risolve allora il problema della diversità dei modelli?

Risposta da dare. Lo risolve ragionando per funzioni e non per organi tipici. La Sezione I del Capitolo 1 definisce tre funzioni — supervisione strategica, gestione e controllo — e riferisce a esse l'intera disciplina; la corrispondenza con gli organi previsti dal codice civile varia a seconda del modello prescelto, ma la funzione resta il termine di riferimento della norma.

Spiegazione. Le definizioni sono precise. L'**organo con funzione di supervisione strategica** è l'organo nel quale si concentrano le funzioni di indirizzo o di supervisione della gestione sociale, per esempio mediante esame e delibera sui piani industriali o finanziari ovvero sulle operazioni strategiche. L'**organo con funzione di gestione** è l'organo, o i componenti di esso, ai quali spettano o sono delegati compiti di gestione, ossia l'attuazione degli indirizzi deliberati nell'esercizio della funzione di supervisione strategica; la Circolare precisa che il direttore generale rappresenta il vertice della struttura interna e come tale partecipa alla funzione di gestione. L'**organo con funzione di controllo** è, a seconda del modello, il collegio sindacale, il consiglio di sorveglianza o il comitato per il controllo sulla gestione.

La Circolare aggiunge un'avvertenza decisiva: più funzioni possono essere svolte dallo stesso organo e più organi possono condividere la stessa funzione. La funzione di supervisione strategica e quella di gestione, attenendo unitariamente all'amministrazione dell'impresa, possono essere incardinate nello stesso organo — ed è ciò che tipicamente avviene nel consiglio di amministrazione del modello tradizionale. Nel modello dualistico, invece, consiglio di sorveglianza e consiglio di gestione possono concorrere nella funzione di supervisione strategica quando lo statuto attribuisca al consiglio di sorveglianza il compito di deliberare sulle operazioni strategiche e sui piani industriali e finanziari, ai sensi dell'art. 2409-terdecies, co. 1, lett. f-bis, c.c.; in tal caso, a fini di vigilanza, la funzione di supervisione strategica si considera incentrata sul consiglio di sorveglianza.

Una quarta nozione completa il quadro, quella di **componenti esecutivi**: sono tali i consiglieri membri del comitato esecutivo, quelli destinatari di deleghe o che svolgono anche di mero fatto funzioni attinenti alla gestione, e quelli che rivestono incarichi direttivi nella banca, cioè che sovrintendono ad aree determinate della gestione assicurando assidua presenza in azienda; rileva anche l'assunzione delle medesime cariche in qualsiasi società del gruppo. La definizione è costruita in modo sostanzialistico — «anche di mero fatto» — proprio per impedire che la qualifica formale di non esecutivo mascheri un ruolo gestorio.

L'approccio funzionale ha un effetto pratico che va segnalato all'orale: la disciplina di vigilanza produce assetti organizzativi sensibilmente diversi da quelli della società per azioni di diritto comune, perché innesta sul modello codicistico vincoli — separatezza di funzioni, riporti diretti,

bilanciamento dei poteri — che il codice civile non conosce. È esattamente per questo che l'art. 53, co. 1, lett. d), è stato esteso al governo societario nel 2011.

1.4. D4 — Gli amministratori indipendenti e i componenti non esecutivi

Domanda. Quale ruolo assegna la disciplina di vigilanza ai componenti non esecutivi e agli amministratori indipendenti, e in che misura ne impone la presenza?

Risposta da dare. La Circolare 285 richiede che nell'organo con funzione di supervisione strategica **almeno un quarto dei componenti** possieda i requisiti di indipendenza. Si tratta di soggetti che, in aggiunta alla generale qualità di non esecutivi, devono possedere professionalità e autorevolezza tali da assicurare un elevato livello di dialettica interna e da apportare un contributo di rilievo alla formazione della volontà dell'organo.

Spiegazione. Conviene distinguere due nozioni che spesso si sovrappongono. I **componenti non esecutivi** sono tutti quelli che non rientrano nella definizione di esecutivi della Sezione I: la loro funzione è di contrappeso rispetto agli esecutivi e al management, e diventa tanto più necessaria quanto più le funzioni di supervisione strategica e di gestione siano concentrate in un unico organo. La Circolare impone loro tre condotte: acquisire informazioni sulla gestione e sull'organizzazione, avvalendosi dei comitati interni ove presenti, dal management, dalla revisione interna e dalle altre funzioni aziendali di controllo; essere fattivamente impegnati nei compiti loro affidati, anche sotto il profilo della disponibilità di tempo; partecipare ai processi di nomina e revoca dei responsabili delle funzioni aziendali di controllo. Quest'ultimo punto è decisivo, perché collega i non esecutivi al presidio dell'indipendenza dei controlli.

Gli **indipendenti** sono una sottocategoria dei non esecutivi. I requisiti sono fissati dall'art. 13 del d.m. 169/2020, che adotta una tecnica per esclusione: è indipendente il consigliere non esecutivo per il quale non ricorra alcuna delle situazioni elencate — fra le altre, l'essere coniuge, parente o affine entro il quarto grado del presidente, degli esponenti con incarichi esecutivi o dei responsabili delle principali funzioni aziendali; l'essere un partecipante nella banca; l'aver ricoperto negli ultimi due anni cariche esecutive presso un partecipante o sue controllate, ovvero per più di nove anni negli ultimi dodici incarichi di componente degli organi. Il decreto detta all'art. 14 requisiti autonomi per i sindaci.

La Circolare aggiunge un onere procedurale non banale: nella delibera consiliare con cui viene valutata l'indipendenza deve risultare, fra l'altro, l'esame di tutti i rapporti creditizi intrattenuti con la banca e riconducibili al consigliere ritenuto indipendente. È un presidio contro l'indipendenza puramente formale, e si collega alla previsione dell'art. 88, par. 1, CRD che impone di documentare e mettere a disposizione delle autorità competenti i dati relativi ai prestiti concessi ai membri dell'organo di gestione e alle loro parti correlate.

Gli indipendenti sono poi il fulcro dell'architettura dei comitati: ciascun comitato endoconsiliare obbligatorio è composto in maggioranza da indipendenti e i suoi lavori sono coordinati da

un presidente scelto fra i componenti indipendenti. Nelle banche che non costituiscono il comitato nomine, sono gli amministratori indipendenti presenti in consiglio a svolgere l'analisi sulla composizione quali-quantitativa ottimale e a esprimere il parere sull'idoneità dei candidati. Il numero dei consiglieri in possesso dei requisiti di indipendenza, e il numero dei consiglieri espressione delle minoranze, rientrano fra le informazioni che la banca deve pubblicare sul proprio sito.

1.5. D5 — Il Risk Appetite Framework: nozione e articolazione

Domanda. Che cos'è il Risk Appetite Framework e quali sono le nozioni che lo compongono?

Risposta da dare. Il RAF è, secondo la definizione della Circolare 285, Capitolo 3, Sezione I, «il quadro di riferimento che definisce — in coerenza con il massimo rischio assumibile, il business model e il piano strategico — la propensione al rischio, le soglie di tolleranza, i limiti di rischio, le politiche di governo dei rischi, i processi di riferimento necessari per definirli e attuarli». È il documento con cui la banca fissa ex ante quanto rischio intende assumere e come reagirà se lo supera.

Spiegazione. Le nozioni che lo compongono vanno tenute distinte con precisione, perché il docente le chiede in sequenza.

Nozione	Definizione
Risk capacity (massimo rischio assumibile)	Il livello massimo di rischio che la banca è tecnicamente in grado di assumere senza violare i requisiti regolamentari o gli altri vincoli imposti dagli azionisti o dall'autorità di vigilanza
Risk appetite (obiettivo di rischio o propensione al rischio)	Il livello di rischio, complessivo e per tipologia, che la banca intende assumere, nel limite del massimo rischio assumibile, per il perseguimento dei suoi obiettivi strategici
Risk tolerance (soglia di tolleranza)	La devianza massima dal risk appetite consentita, fissata in modo da assicurare margini sufficienti per operare anche in condizioni di stress entro il massimo rischio assumibile
Risk profile (rischio effettivo)	Il rischio effettivamente assunto, misurato in un determinato istante temporale
Risk limits (limiti di rischio)	L'articolazione degli obiettivi di rischio in limiti operativi, definiti per tipologie di rischio, unità o linee di business, linee di prodotto, tipologie di clienti

La logica è quella di una scala discendente: la *capacity* è il vincolo esterno, l'*appetite* è la scelta imprenditoriale entro quel vincolo, la *tolerance* è lo scostamento ammesso, i *limits* sono la traduzione operativa dell'*appetite* nelle singole strutture, e il *profile* è la misurazione di ciò che effettivamente accade. Se è consentita l'assunzione di rischio oltre l'obiettivo fissato, fermo il rispetto della soglia di tolleranza, devono essere individuate le azioni gestionali necessarie per ricondurre il rischio entro l'obiettivo prestabilito: il RAF non è una fotografia ma un meccanismo di retroazione.

L'Allegato C al Capitolo 3 fornisce le indicazioni di contenuto. Il RAF, tenuto conto del piano strategico e dei rischi rilevanti ivi individuati e definito il massimo rischio assumibile, indica le tipologie di rischio che la banca intende assumere e, per ciascuna, fissa obiettivi, eventuali soglie di tolleranza e limiti operativi sia in condizioni di normale operatività sia di stress; indica le circostanze, inclusi gli esiti degli scenari di stress, al ricorrere delle quali l'assunzione di determinate categorie di rischio va evitata o contenuta. Obiettivi, soglie e limiti sono di norma declinati in termini di misure espressive del capitale a rischio o capitale economico — VaR, *expected shortfall* — di adeguatezza patrimoniale e di liquidità. Per i rischi **difficilmente quantificabili**, quali il rischio strategico, il rischio reputazionale o il rischio di *compliance*, il RAF fornisce indicazioni di carattere qualitativo idonee a orientare la definizione e l'aggiornamento dei processi e dei presidi del sistema dei controlli interni. Il RAF precisa infine i compiti degli organi e di tutte le funzioni coinvolte, nonché tempistiche e modalità di aggiornamento.

1.6. D6 — Il sistema dei controlli interni: nozione, finalità e principi di organizzazione

Domanda. Come definisce la Circolare 285 il sistema dei controlli interni e quali finalità gli assegna?

Risposta da dare. Il sistema dei controlli interni è definito come «l'insieme delle regole, delle funzioni, delle strutture, delle risorse, dei processi e delle procedure che mirano ad assicurare, nel rispetto della sana e prudente gestione, il conseguimento» di una serie di finalità tassativamente elencate. La premessa del Capitolo 3 lo qualifica come «elemento fondamentale del complessivo sistema di governo delle banche», che assicura che l'attività aziendale sia in linea con le strategie e le politiche aziendali.

Spiegazione. Le finalità sono sette e vanno ricordate: verifica dell'attuazione delle strategie e delle politiche aziendali; contenimento del rischio entro i limiti indicati nel RAF; salvaguardia del valore delle attività e protezione dalle perdite; efficacia ed efficienza dei processi aziendali; affidabilità e sicurezza delle informazioni aziendali e delle procedure informatiche; prevenzione del rischio che la banca sia coinvolta, anche involontariamente, in attività illecite, con particolare riferimento a quelle connesse con il riciclaggio, l'usura e il finanziamento al terrorismo; conformità delle operazioni con la legge e la normativa di vigilanza, nonché con le politiche, i regolamenti e le procedure interne.

Due di queste meritano un rilievo. La sesta è la sola finalità in cui la disciplina del sistema dei controlli interni richiama espressamente il contrasto al riciclaggio, che ha una propria disciplina autonoma nel d.lgs. 231/2007: il collegamento è organizzativo, non sostanziale, ed è coerente con la premessa del Capitolo 1, che colloca l'antiriciclaggio fra le discipline che si affiancano a quella del governo societario. La settima introduce il concetto di **conformità**, traduzione di *compliance*, che dà il nome a una delle tre funzioni aziendali di controllo.

La Circolare insiste sul **ruolo centrale** del sistema: esso rappresenta un elemento fondamentale di conoscenza per gli organi aziendali, orienta i mutamenti delle linee strategiche, presidia la funzionalità dei sistemi gestionali e il rispetto degli istituti di vigilanza prudenziale, favorisce la diffusione di una corretta cultura dei rischi, della legalità e dei valori aziendali. Da qui l'affermazione che «la cultura del controllo deve avere una posizione di rilievo nella scala dei valori aziendali: non riguarda solo le funzioni aziendali di controllo, ma coinvolge tutta l'organizzazione aziendale». Il controllo non è un ufficio, è un modo di operare.

Per realizzare l'obiettivo, il sistema deve in generale: assicurare completezza, adeguatezza, funzionalità e affidabilità del processo di gestione dei rischi e la sua coerenza con il RAF; prevedere attività di controllo diffuse a ogni segmento operativo e livello gerarchico; garantire che le anomalie riscontrate siano tempestivamente portate a conoscenza di livelli appropriati — agli organi aziendali, se significative — in grado di attivare gli opportuni interventi correttivi; incorporare procedure specifiche per far fronte all'eventuale violazione dei limiti operativi; assicurare che il personale conosca le componenti del sistema e le principali politiche, in particolare la politica di *compliance*.

Due principi generali di organizzazione chiudono la Sezione I: i processi decisionali e l'affidamento di funzioni al personale sono formalizzati e consentono l'univoca individuazione di compiti e responsabilità, e sono idonei a prevenire i conflitti di interessi — in tale ambito «deve essere assicurata la necessaria **separatezza** tra le funzioni operative e quelle di controllo»; e le politiche di gestione delle risorse umane assicurano che il personale sia provvisto delle competenze necessarie. Le disposizioni si applicano secondo proporzionalità, tenuto conto del profilo di rischio, della dimensione e complessità operativa, della natura dell'attività e della tipologia dei servizi prestati. Infine: i presidi devono coprire **ogni tipologia di rischio aziendale**, la responsabilità primaria è rimessa agli organi aziendali ciascuno secondo le rispettive competenze, e l'articolazione di compiti e responsabilità deve essere chiaramente definita e formalizzata.

1.7. D7 — I tre livelli di controllo e le «tre linee di difesa»

Domanda. Come si articolano i controlli interni di una banca, e che rapporto c'è fra la tripartizione della Circolare e il modello delle «tre linee di difesa»?

Risposta da dare. La Circolare 285 individua, a prescindere dalle strutture in cui sono collocati, tre tipologie di controllo: controlli di linea o di primo livello, controlli sui rischi e sulla conformità o di secondo livello, revisione interna o controlli di terzo livello. È bene precisare subito che la Circolare usa la nozione di **livello**, non quella di «linea di difesa»: quest'ultima è terminologia di matrice internazionale, accolta dal Comitato di Basilea nei «Corporate governance principles for banks» del 2015 e ripresa dagli orientamenti dell'EBA sulla governance interna, che si sovrappone alla tripartizione italiana senza esserne la traduzione letterale.

Spiegazione. I **controlli di linea**, o di primo livello, sono diretti ad assicurare il corretto svolgimento delle operazioni. Sono effettuati dalle stesse strutture operative — controlli di tipo gerarchico, sistematici e a campione — anche attraverso unità dedicate esclusivamente a compiti

di controllo che riportano ai responsabili delle strutture operative, ovvero eseguiti nell'ambito del *back office*; per quanto possibile sono incorporati nelle procedure informatiche. L'esempio tipico è il responsabile di filiale che a fine giornata verifica la regolarità delle operazioni eseguite.

I **controlli di secondo livello** hanno l'obiettivo di assicurare, fra l'altro, la corretta attuazione del processo di gestione dei rischi, il rispetto dei limiti operativi assegnati alle varie funzioni e la conformità dell'operatività aziendale alle norme, incluse quelle di autoregolamentazione. Sono affidati a due funzioni distinte: il controllo dei rischi, o *risk management*, e la conformità alle norme, o *compliance*. Il riferimento all'autoregolamentazione va inteso in senso pieno: comprende statuti, codici di condotta, codici di autodisciplina e regolamentazione interna.

La **revisione interna**, o controllo di terzo livello, è volta a individuare violazioni delle procedure e della regolamentazione, nonché a valutare periodicamente la completezza, l'adeguatezza, la funzionalità e l'affidabilità del sistema dei controlli interni e del sistema informativo — l'*ICT audit* — con cadenza prefissata in relazione alla natura e all'intensità dei rischi. È la funzione che controlla i controllori, e per questa ragione la Circolare stabilisce che le funzioni di conformità e di controllo dei rischi non possono esserle affidate: sono soggette alla sua verifica periodica, e attribuirglielne comprometterebbe l'imparzialità delle verifiche.

Livello	Chi lo svolge	Oggetto
Primo — controlli di linea	Strutture operative, back office, procedure informatiche	Corretto svolgimento delle operazioni
Secondo — rischi e conformità	Funzione di controllo dei rischi; funzione di conformità alle norme	Attuazione del processo di gestione dei rischi, rispetto dei limiti operativi, conformità alle norme
Terzo — revisione interna	Funzione di revisione interna	Violazioni di procedure e regolamentazione; valutazione periodica del SCI e del sistema informativo

La separazione non è solo terminologica: i controlli di secondo livello non possono essere affidati ai medesimi soggetti che svolgono i controlli di primo livello, perché nessuno può verificare con imparzialità le proprie operazioni. È l'applicazione del principio di separatezza fra funzioni operative e funzioni di controllo enunciato nella stessa Sezione I.

1.8. D8 — Compliance, risk management e internal audit: contenuti specifici

Domanda. Quali sono i compiti propri della funzione di conformità alle norme, della funzione di controllo dei rischi e della funzione di revisione interna?

Risposta da dare. La funzione di **conformità** presidia il rischio di non conformità alle norme; la funzione di **controllo dei rischi** collabora alla definizione e all'attuazione del RAF e delle relative politiche di governo dei rischi attraverso un adeguato processo di gestione; la funzione di **revisione interna** verifica la regolarità delle attività e valuta periodicamente il si-

stema dei controlli interni. Sono tre mestieri diversi: il primo giuridico-organizzativo, il secondo prevalentemente quantitativo, il terzo di verifica.

Spiegazione. Il **rischio di non conformità alle norme** è definito dalla Circolare come «il rischio di incorrere in sanzioni giudiziarie o amministrative, perdite finanziarie rilevanti o danni di reputazione in conseguenza di violazioni di norme imperative (leggi, regolamenti) ovvero di autoregolamentazione (ad es., statuti, codici di condotta, codici di autodisciplina)». Poiché è diffuso a tutti i livelli dell'organizzazione, soprattutto nelle linee operative, l'attività di prevenzione deve svolgersi in primo luogo dove il rischio viene generato: di qui la necessità di un'adeguata responsabilizzazione di tutto il personale. I compiti principali della funzione sono: ausilio alle strutture per la definizione delle metodologie di valutazione dei rischi di non conformità; individuazione di idonee procedure di prevenzione, con possibilità di richiederne l'adozione; verifica della loro adeguatezza e corretta applicazione; identificazione nel continuo delle norme applicabili e misurazione del loro impatto su processi e procedure. Fra le aree di intervento ulteriori, la Circolare indica il coinvolgimento nella valutazione ex ante della conformità di tutti i progetti innovativi — inclusa l'operatività in nuovi prodotti o servizi — e nella prevenzione e gestione dei conflitti di interesse, sia fra le diverse attività della banca sia con riferimento a dipendenti ed esponenti. Restano ferme le responsabilità della *compliance* per i compiti previsti da normative specifiche, fra cui la disciplina delle politiche di remunerazione, la trasparenza delle operazioni e la disciplina delle attività di rischio verso soggetti collegati.

La funzione di **controllo dei rischi** ha la finalità di collaborare alla definizione e all'attuazione del RAF e delle relative politiche di governo dei rischi. La differenza con la *compliance* è di metodo prima che di oggetto: la conformità ragiona su norme e procedure, il controllo dei rischi su misure e modelli. Le due funzioni possono essere affidate a un'unica struttura nelle banche in cui ciò sia coerente con la proporzionalità, ma devono in ogni caso restare coordinate con la revisione interna.

La **revisione interna**, coerentemente con il piano di audit, verifica anche mediante accertamenti di natura ispettiva: la regolarità delle diverse attività aziendali, incluse quelle esternalizzate, e l'evoluzione dei rischi sia nella direzione generale sia nelle filiali — con frequenza coerente con l'attività svolta e la propensione al rischio, ma conducendo anche accertamenti ispettivi «casuali e non preannunciati»; il monitoraggio della conformità alle norme a tutti i livelli aziendali; il rispetto, nei diversi settori operativi, dei limiti previsti dai meccanismi di delega e il pieno e corretto utilizzo delle informazioni disponibili. La previsione delle ispezioni non preannunciate è il tratto che distingue questa funzione dalle altre e che ne spiega la collocazione alle dirette dipendenze dell'organo con funzione di supervisione strategica.

1.9. D9 — Le politiche di remunerazione e incentivazione: fondamento e principi generali

Domanda. Su quale base e con quali finalità la vigilanza disciplina le politiche di remunerazione delle banche?

Risposta da dare. Il Capitolo 2 del Titolo IV è adottato sulla base degli artt. 53 e 67 TUB e dà attuazione alla direttiva 2013/36/UE, come modificata dalla direttiva (UE) 2019/878 (CRD V), tenendo conto degli indirizzi concordati in sede internazionale, fra cui quelli dell'EBA e del Financial Stability Board. La ragione della disciplina è che un sistema retributivo mal congegnato è esso stesso una fonte di rischio prudenziale.

Spiegazione. La Circolare lo enuncia in termini espliciti: i sistemi di remunerazione e incentivazione devono essere in linea con valori, strategie e obiettivi aziendali di lungo periodo, collegati ai risultati aziendali e opportunamente corretti per tener conto di tutti i rischi, coerenti con i livelli di capitale e di liquidità necessari a fronteggiare le attività intraprese e, in ogni caso, «tali da evitare incentivi distorti che possano indurre a violazioni normative o ad un'eccessiva assunzione di rischi per la banca e il sistema finanziario nel suo complesso». È la lezione della crisi del 2007-2008: bonus commisurati a risultati di breve periodo e non corretti per il rischio spingono il *management* ad assumere esposizioni i cui effetti si manifesteranno quando il bonus è già stato incassato.

Il Capitolo riconosce anche la funzione positiva della remunerazione: adeguati meccanismi possono favorire la competitività e il buon governo delle imprese bancarie e servono ad attrarre e trattenere professionalità adeguate. Ma i sistemi retributivi devono essere definiti in coerenza con obiettivi e valori aziendali, «ivi inclusi gli obiettivi di finanza sostenibile che tengono conto, tra l'altro, dei fattori ambientali, sociali e di governance (ESG)», con le strategie di lungo periodo e con le politiche di prudente gestione del rischio, comprese le strategie di monitoraggio e gestione dei crediti deteriorati. Le forme di retribuzione incentivante basate su strumenti finanziari — per esempio le *stock option* — o collegate alla *performance* aziendale devono essere coerenti con il RAF e con le politiche di governo e di gestione dei rischi, tenere conto del costo e del livello del capitale e della liquidità necessari, ed essere strutturate in modo da evitare incentivi in conflitto con l'interesse della società in un'ottica di lungo periodo. La CRD, all'art. 74, par. 1, aggiunge che le politiche e prassi di remunerazione devono essere **neutrali rispetto al genere**.

Due previsioni antielusive chiudono i principi generali. Le banche assicurano che il proprio personale non sia remunerato né riceva pagamenti o altri benefici tramite veicoli, strumenti o modalità comunque elusive delle disposizioni, con riguardo anche a succursali e filiazioni estere ovunque insediate. E le banche richiedono al personale, attraverso specifiche pattuizioni, di non avvalersi di **strategie di copertura personale** o di assicurazioni sulla retribuzione che possano alterare gli effetti di allineamento al rischio dei meccanismi retributivi: sarebbe infatti agevole neutralizzare il differimento e il *malus* assicurandosi contro di essi. Coerentemente, le banche richiedono al personale più rilevante di comunicare le operazioni effettuate che potrebbero incidere sui profili di rischio della propria remunerazione.